MODULE 27 · DOMAIN 6 - SECURITY AND COMPLIANCE

Detection and Posture at Scale

GuardDuty and Extended Threat Detection, Security Hub CSPM and the new Security Hub, Inspector, Macie, Detective, and organisation-wide CloudTrail.

DOMAIN 6 of 6 EXAM WEIGHT 17% MODULE 27 of 34

admin@sthithapragna.com

Each service has one **verb**. GuardDuty **detects**, Inspector **scans**, Macie **discovers**, Security Hub **aggregates**, Detective **explains**.

One verb each

SERVICE	VERB	LOOKS AT
GuardDuty	Detects threats	CloudTrail, VPC flows, DNS, plus protection plans
Inspector	Scans for vulnerabilities	EC2, ECR images, Lambda, code repositories
Macie	Discovers sensitive data	The contents of S3 objects
Security Hub CSPM	Scores posture, aggregates findings	Controls against standards, via Config
Detective	Explains incidents	A behaviour graph of activity over time
CloudTrail	Records API activity	Every account, every Region

ON THE EXAM

Most of these are Regional, and all support a delegated administrator for the whole organisation.

Amazon GuardDuty

- Foundational sources: CloudTrail management events, VPC Flow Logs and DNS logs, read **independently**.
- You do not need to enable or pay for those logs yourself for GuardDuty to use them.
- Protection plans: S3, EKS, Runtime Monitoring, Malware Protection for EC2 and S3, RDS, Lambda.
- Enable organisation-wide from a **delegated administrator**, with auto-enable for new accounts, in every Region.

> ON THE EXAM
>
> Findings go to EventBridge automatically, so every GuardDuty finding can trigger module 21's responses.

Extended Threat Detection

- GA December 2024: correlates many signals into one **attack sequence** finding, at critical severity.
- Maps to MITRE ATT&CK tactics; covers credential compromise, S3 data compromise, EKS compromise.
- Since May 2026, indicators also come from Inspector, Macie and Security Hub CSPM, if enabled.
- Automatically on, at no extra cost.

> ON THE EXAM
>
> Many related findings, but no single incident view: Extended Threat Detection's attack sequences.

Tuning GuardDuty

- **Suppression rules** archive expected findings automatically, such as a known scanner.
- **Trusted IP lists** and **threat lists** tell GuardDuty which addresses to trust or flag.
- Severity is low, medium, high or critical; route by severity with EventBridge patterns.
- Suppressing findings hides them. Fix the cause where you can.

> ON THE EXAM
>
> A known vulnerability scanner keeps generating findings: a suppression rule, not disabling GuardDuty.

Security Hub CSPM, or the new Security Hub?

SECURITY HUB (NEW, DECEMBER 2025)

Correlates and prioritises

- Correlates GuardDuty, Inspector, Macie and CSPM signals
- Exposure findings and attack paths
- Prioritised, unified security operations
- Includes CSPM as one component

SECURITY HUB CSPM

What 'Security Hub' used to mean

- Standards: FSBP, CIS, PCI DSS, NIST
- Controls evaluated through AWS Config
- Security score and aggregated findings
- What the exam guide means by 'Security Hub'

THE RULE

The exam guide says 'Security Hub'. Answer with the CSPM behaviour: standards, controls, Config, aggregation.

Security Hub CSPM in practice

- Controls depend on **AWS Config** recording in every account and Region. No recorder, no score.
- **Central configuration** from a delegated administrator sets standards and controls organisation-wide.
- A **cross-Region aggregator** brings every Region's findings into one.
- **Automation rules** update findings; **custom actions** send chosen findings to EventBridge.

> ON THE EXAM
>
> Controls show no data in some accounts or Regions: AWS Config is not recording there.

Amazon Inspector

- Scans EC2 instances, ECR images and Lambda functions for software vulnerabilities and network reachability.
- **Rescans automatically** when a new vulnerability is published, not just at deployment.
- Code security (June 2025) scans repositories; findings flow to Security Hub and EventBridge.
- **Inspector Classic** reached end of support in May 2026.

> ON THE EXAM
>
> Continuous vulnerability scanning of instances, images and functions across the organisation: Inspector.

Amazon Macie

- Discovers sensitive data, such as personal data and credentials, inside S3 objects.
- **Automated sensitive data discovery** samples buckets continuously, at low cost, across the organisation.
- Targeted **discovery jobs** scan chosen buckets in depth, with managed and custom data identifiers.
- Also reports bucket security, such as public or unencrypted buckets.

> ON THE EXAM
>
> Which buckets across 200 accounts contain personal data: Macie automated discovery from a delegated administrator.

Macie or GuardDuty S3 Protection?

MACIE

What is in the objects

- Reads object contents
- Finds personal data and secrets
- Answers: where is our sensitive data?
- Posture and compliance

GUARDDUTY S3 PROTECTION

How the objects are accessed

- Watches access behaviour
- Finds unusual reads, exfiltration, disabled logging
- Answers: is someone attacking our data?
- Threat detection

THE TIEBREAKER

Neither answers the other's question. Contents: Macie. Behaviour: GuardDuty.

Amazon Detective

- Builds a **behaviour graph** from CloudTrail, VPC flows, GuardDuty findings and EKS audit logs.
- Shows what a principal, instance or IP did over time, compared with its normal baseline.
- **Finding groups** gather related findings; investigations summarise risky behaviour.
- Detective explains an incident. It does not produce the original finding.

> ON THE EXAM
>
> 'What else did this compromised role touch over the past month?': Detective, not hand-written Athena queries.

CloudTrail across an organisation

- An **organisation trail** logs every account and Region to one bucket in the log archive account.
- **Log file validation** produces digest files that prove logs were not altered.
- Protect the bucket with Object Lock and a KMS key; limit who can read it.
- **CloudTrail Insights** flags unusual API call rates or error rates.

> ON THE EXAM
>
> Prove audit logs were not tampered with: log file validation, plus an immutable, separate log archive bucket.

From finding to response

01
Detect
GuardDuty, Inspector, Macie, CSPM controls.

›

02
Aggregate
Security Hub gathers every finding.

›

03
Route
EventBridge rules by type and severity.

›

04
Respond
Runbooks, workflows, notifications.

›

05
Investigate
Detective for what happened and how far.

ON THE EXAM

Detection without a routed response is a dashboard nobody reads. Every finding type should have a destination.

> A company with 150 accounts in AWS Organizations wants GuardDuty running in every account and every Region, including accounts created in future.
>
> The security team works in a dedicated security tooling account and wants the least operational overhead.

What should the DevOps engineer do?

A. Enable GuardDuty by hand in each account and Region

B. A StackSet that enables GuardDuty in every account

C. Make the security tooling account GuardDuty's delegated administrator, and turn on auto-enable for all accounts, in each Region

D. An AWS Config rule that reports accounts without GuardDuty

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A **By hand**
Thousands of account-Region pairs, and new accounts are missed.

B **StackSet**
Possible, but reinvents the service's own organisation feature, with member linkage to manage.

C **Delegated admin with auto-enable**
Every existing and future account enrolled, findings central, managed from the tooling account.

D **Config rule**
Reports the gap. Enables nothing.

THE SIGNAL

Organisation-wide security service, future accounts included: delegated administrator plus auto-enable, per Region.

> Over a day, a security team receives dozens of GuardDuty findings: unusual API calls from a role, then S3 reads from a new location, then disabled bucket logging.
>
> Analysts treat them separately and miss that they form one attack. The team wants a single, prioritised finding that ties them together.

What provides this?

A Aggregating the findings in Security Hub CSPM

B Amazon Detective finding groups, reviewed by hand

C A CloudWatch composite alarm over the finding counts

D GuardDuty Extended Threat Detection attack sequence findings, with S3 Protection enabled

◆ PAUSE AND DECIDE

What provides this?

A **CSPM aggregation**

Puts the findings in one place. Still dozens of separate findings.

B **Detective by hand**

Helps investigate once someone suspects, but it is not the automatic single finding.

C **Composite alarm**

Counts findings. Knows nothing about how they relate.

D **Attack sequences**

Correlates the signals into one critical finding, mapped to attack tactics.

THE SIGNAL

Aggregating is not correlating. One finding for one attack: Extended Threat Detection.

> Security Hub CSPM is enabled across the organisation with the AWS Foundational Security Best Practices standard. In accounts recently added in eu-central-1, controls show no data and no security score.
>
> GuardDuty works normally in those accounts.

What is the most likely cause?

A GuardDuty is not sending findings to Security Hub

B Macie is not enabled in those accounts

C AWS Config is not recording in those accounts and that Region

D Inspector is not enabled in those accounts

◆ PAUSE AND DECIDE

What is the most likely cause?

A **GuardDuty integration**

GuardDuty findings are separate from control evaluations. Controls need Config.

B **Macie**

Not required for controls to evaluate.

C **Config not recording**

CSPM controls evaluate through Config. No recorder there means no data and no score.

D **Inspector**

Not required for controls to evaluate.

THE SIGNAL

CSPM controls with no data: AWS Config is missing in that account and Region.

> A company runs EC2 instances, container images in ECR, and Lambda functions across 60 accounts. It must know about vulnerable software in all of them, including when a new vulnerability is published for software already deployed.
>
> The company wants the least operational overhead.

What should the DevOps engineer enable?

A ECR basic scanning on every repository

B A third-party scanner run weekly from a pipeline

C Amazon Inspector Classic in each account

D Amazon Inspector for EC2, ECR and Lambda, organisation-wide from a delegated administrator

◆ PAUSE AND DECIDE

What should the DevOps engineer enable?

A ECR basic scanning

Images only, OS packages only, and no continuous rescanning.

B Weekly third-party scan

Up to a week late, and a pipeline to maintain.

C Inspector Classic

End of support in May 2026, and it never covered images or functions.

D Amazon Inspector, organisation-wide

All three resource types, rescanned automatically on new vulnerabilities, centrally.

THE SIGNAL

Instances, images and functions, rescanned on new CVEs, org-wide: Inspector from a delegated administrator.

> A company has thousands of S3 buckets across 200 accounts. A regulator asks which buckets contain personal data, and requires this to be kept up to date continuously.
>
> The company wants the lowest cost and least operational overhead.

What should the DevOps engineer use?

A. Amazon Macie automated sensitive data discovery, organisation-wide from a delegated administrator

B. GuardDuty S3 Protection in every account

C. Athena queries over every bucket's contents

D. Amazon Inspector in every account

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A Macie automated discovery

Samples every bucket continuously, cheaply, and maps where personal data lives.

B GuardDuty S3 Protection

Watches access behaviour. It never reads object contents.

C Athena over everything

Only works on structured data, and scanning everything is costly and custom.

D Inspector

Scans software vulnerabilities, not data.

THE SIGNAL

Where is our personal data: Macie. Automated discovery keeps it continuous and cheap.

> GuardDuty reports that credentials for a CI role were used from an unusual location. The team must find out what else that role did over the past three weeks, and which resources it touched.
>
> It wants a visual answer quickly, without writing queries.

What should the team use?

A Athena queries over the organisation trail

B Amazon Detective, from the GuardDuty finding

C Security Hub CSPM's findings list

D CloudTrail event history in the console, Region by Region

◆ PAUSE AND DECIDE

What should the team use?

A. Athena queries

Can answer it, but only by writing queries, which the team wants to avoid.

B. Detective

Opens from the finding into a behaviour graph of what the role did and touched, over time.

C. CSPM findings

Lists findings. Does not reconstruct a principal's activity.

D. Event history by Region

Slow, one Region at a time, and no picture of the whole.

THE SIGNAL

Explain what a compromised principal did, visually, without queries: Detective.

Module 27, and the teaching content, in five lines

- GuardDuty detects, Inspector scans, Macie discovers, Security Hub aggregates, Detective explains.
- Delegated administrator plus auto-enable, in every Region, covers future accounts.
- Extended Threat Detection correlates; aggregation alone does not.
- 'Security Hub' in the guide means CSPM behaviour, which needs AWS Config everywhere.
- Contents: Macie. Behaviour: GuardDuty. Retired: Inspector Classic.

> ON THE EXAM
>
> Domain 6 and all teaching modules complete. Next, module 28: confusion pairs.